PRESENTACIÓN • CIBERSEGURIDAD

Defensa en profundidad y controles de acceso

Elmer C.

Estrategias, capas de protección y gestión de permisos

Defensa en profundidad

01 ¿QUÉ ES LA DEFENSA EN PROFUNDIDAD EN CIBERSEGURIDAD?

Es una estrategia que utiliza varias capas de seguridad para proteger sistemas, redes y datos.

02 ¿CUÁL ES EL OBJETIVO PRINCIPAL DE IMPLEMENTAR MÚLTIPLES CAPAS DE SEGURIDAD?

Evitar que una sola vulnerabilidad permita comprometer toda la infraestructura.

03 ¿QUÉ CAPAS DE PROTECCIÓN PUEDEN FORMAR PARTE DE UNA ESTRATEGIA DE DEFENSA EN PROFUNDIDAD?

Seguridad física, redes, firewalls, antivirus, control de acceso, cifrado y monitoreo.

04 ¿QUÉ SUCEDE CUANDO UNA DE LAS CAPAS DE SEGURIDAD ES VULNERADA?

Las demás capas siguen protegiendo el sistema y dificultan que el atacante avance.

05 ¿POR QUÉ LA DEFENSA EN PROFUNDIDAD NO DEBE DEPENDER EXCLUSIVAMENTE DE HERRAMIENTAS TECNOLÓGICAS?

Porque también depende de las personas, la capacitación, las políticas y los procedimientos de seguridad.

Controles de acceso

01 ¿QUÉ ES UN CONTROL DE ACCESO EN CIBERSEGURIDAD?

Es un mecanismo que permite controlar quién puede acceder a un sistema o recurso.

02 ¿CUÁL ES LA DIFERENCIA ENTRE IDENTIFICACIÓN, AUTENTICACIÓN Y AUTORIZACIÓN?

Identificación: Decir quién eres.
Autenticación: Demostrar quién eres.
Autorización: Definir qué puedes hacer.

03 ¿QUÉ DIFERENCIAS EXISTEN ENTRE DAC, MAC, RBAC Y ABAC?

DAC: El propietario decide quién accede. MAC: El acceso depende de niveles de seguridad.
RBAC: El acceso depende del rol del usuario. ABAC: El acceso depende de atributos y condiciones.

04 ¿QUÉ ES EL PRINCIPIO DE MÍNIMO PRIVILEGIO?

Dar a cada usuario únicamente los permisos necesarios para realizar su trabajo.

05 ¿QUÉ IMPORTANCIA TIENE LA AUTENTICACIÓN MULTIFACTOR (MFA)?

Porque también depende de las personas, la capacitación, las políticas y los procedimientos de seguridad.

06 ¿CUÁL ES LA DIFERENCIA ENTRE CONTROLES DE ACCESO FÍSICOS Y LÓGICOS?

Físicos: Protegen lugares y equipos (cerraduras, tarjetas).
Lógicos: Protegen sistemas y datos (contraseñas, MFA).

GUÍA RÁPIDA

DAC
El dueño decide

MAC
Clasificación

RBAC
Roles

ABAC
Atributos

MFA
Varios factores

Mínimo privilegio
Solo lo necesario

Relación entre defensa en profundidad y controles de acceso

01 ¿CÓMO CONTRIBUYEN LOS CONTROLES DE ACCESO A UNA ESTRATEGIA DE DEFENSA EN PROFUNDIDAD?

Agregan capas de seguridad para evitar que un atacante acceda a información o sistemas.

02 ¿POR QUÉ UN FIREWALL NO ES SUFICIENTE PARA IMPEDIR TODOS LOS ACCESOS NO AUTORIZADOS?

Porque solo controla parte del tráfico y no evita todos los ataques o robos de credenciales.

03 ¿CÓMO SE COMPLEMENTAN LA AUTENTICACIÓN MULTIFACTOR, LA SEGMENTACIÓN DE RED Y LOS PERMISOS DE USUARIO?

MFA: Verifica la identidad. Segmentación: Separa las redes. Permisos: Limita lo que puede hacer cada usuario.

04 ¿QUÉ RIESGOS EXISTIRÍAN SI UN ATACANTE OBTIENE LAS CREDENCIALES DE UN ADMINISTRADOR?

Podría controlar sistemas, robar información y modificar configuraciones.

05 ¿CÓMO PUEDE UNA ORGANIZACIÓN LIMITAR EL MOVIMIENTO LATERAL DE UN ATACANTE MEDIANTE CONTROLES DE ACCESO?

Separando las redes y limitando los permisos de cada usuario.

06 ¿QUÉ RELACIÓN EXISTE ENTRE DEFENSA EN PROFUNDIDAD, MÍNIMO PRIVILEGIO Y ZERO TRUST?

Los tres buscan reducir riesgos: usar varias capas de seguridad, dar solo los permisos necesarios y nunca confiar sin verificar.

Infraestructura empresarial

1. IDENTIFICAR CINCO RIESGOS DE SEGURIDAD

1. **Robo de contraseñas**
   Un atacante podría entrar usando credenciales robadas.
2. **Falta de MFA**
   Solo se utiliza usuario y contraseña.
3. **Acceso excesivo**
   Todos pueden entrar a cualquier servidor.
4. **Falta de segmentación**
   Un atacante podría moverse entre los servidores.
5. **Robo de información**
   Un empleado podría acceder y modificar la base de datos sin autorización.

2. PROPONER CINCO CONTROLES DE ACCESO

1. **MFA**
   Agregar una segunda verificación de identidad.
2. **RBAC**
   Asignar permisos según el puesto.
3. **Mínimo privilegio**
   Dar solo los permisos necesarios.
4. **Segmentación de red**
   Separar computadoras y servidores.
5. **VPN segura**
   Proteger el acceso remoto con MFA.

Estrategia de defensa en profundidad

3. ESTRATEGIA DE DEFENSA EN PROFUNDIDAD

01 Física

Proteger los equipos y servidores.

02 Perimetral

Utilizar el firewall.

03 Red

Separar las redes mediante VLAN.

04 Identidad

Implementar MFA y permisos.

05 Aplicaciones

Limitar el acceso según las funciones.

06 Datos

Cifrar y proteger la información.

4. ¿CÓMO IMPEDIR QUE UN EMPLEADO COMPROMETIDO ACCEDA A LA BASE DE DATOS?

- MFA: Verifica la identidad.
- RBAC: Limita los permisos.
- Segmentación: Bloquea conexiones innecesarias.
- Mínimo privilegio: Permite acceder solo a lo necesario.

Diagrama de defensa en profundidad

CAPAS COMPLEMENTARIAS DE PROTECCIÓN

1. **Seguridad física** — Protege equipos.
2. **Seguridad perimetral** — Filtra.
3. **Seguridad de red** — Separa.
4. **Seguridad de identidad** — Verifica.
5. **Seguridad de aplicaciones** — Controla.
6. **Seguridad de datos** — Protege información.

OBJETIVO

Si una capa falla, las demás siguen aportando protección y reducen la posibilidad de que el atacante avance.

Principio clave

La seguridad es más efectiva cuando las capas trabajan juntas.

Cuadro comparativo

CAPA DE DEFENSA	CONTROL DE ACCESO PROPUESTO	AMENAZA QUE AYUDA A MITIGAR
Seguridad física	Cerraduras y tarjetas de acceso.	Robo o manipulación de equipos.
Seguridad perimetral	Firewall y VPN con MFA.	Accesos externos no autorizados.
Seguridad de red	VLAN y ACL.	Movimiento lateral de atacantes.
Seguridad de identidad	MFA y Active Directory.	Robo de credenciales.
Seguridad de aplicaciones	Permisos por roles (RBAC).	Acceso indebido a aplicaciones.
Seguridad de datos	Cifrado y permisos de lectura y escritura.	Robo o modificación de información.

Conclusión personal

La defensa en profundidad es importante porque permite proteger una empresa mediante diferentes capas de seguridad. Considero que implementar MFA, segmentación de red y mínimo privilegio ayuda a reducir los accesos no autorizados y proteger la información. Ningún control es suficiente por sí solo, por eso es necesario combinar diferentes medidas de seguridad.

REFERENCIAS BIBLIOGRÁFICAS

1. **NIST – Zero Trust Architecture. Publicación SP 800-207.**
   Consultar NIST SP 800-207.

2. **CISA – Zero Trust Maturity Model.**
   Consultar modelo Zero Trust.

3. **NIST – Security and Privacy Controls. Publicación SP 800-53.**
   Consultar NIST SP 800-53.